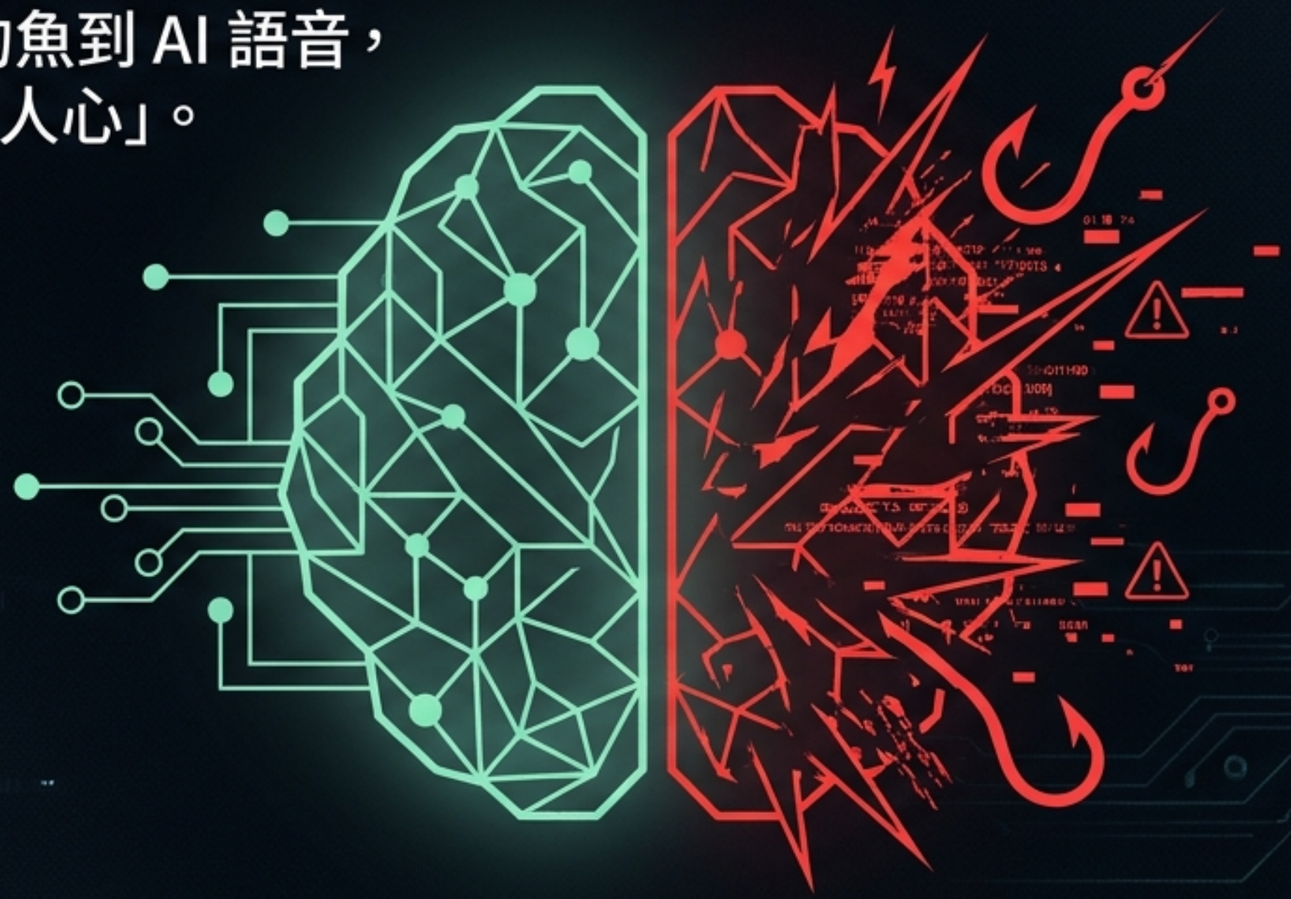
社交工程：拆解數位時代的心理幻術

從實體誘餌、網路釣魚到 AI 語音，
解析駭客如何駭入「人心」。



PR0JECT: PSYCHE-BREACH
DOSSIER ID: SE-2024-X7

CLASSIFIED

Gemini Notebook

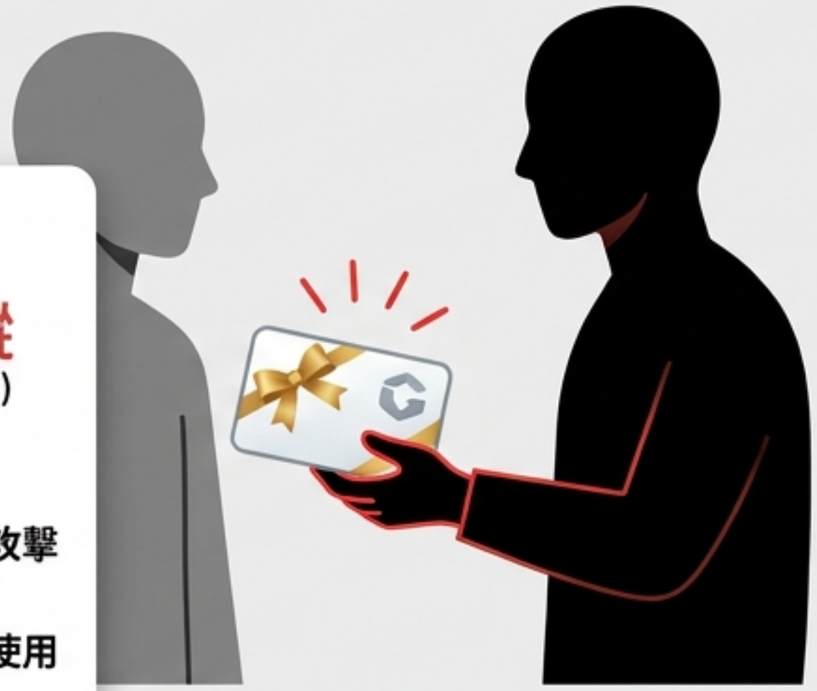


社交工程 =

偽裝合法交流 × **心理操縱**
(貪婪/恐懼/好奇)

→ 繞過系統防線

最大的資安漏洞，是「人性」。社交工程並不攻擊電腦漏洞，而是將人類視為系統中最脆弱的節點。駭客透過合法的交流外衣，直接「駭入」使用者的心理，讓使用者親手交出鑰匙。



系統防禦 (System Defense)

堅不可摧的防火牆與多重密碼鎖

心理駭客 (Psychological Hacker)

遞出偽裝精美的誘餌，繞過防線

Gemini Notebook

威脅模型 (Threat Model)

社交工程威脅三角



下餌 (Baiting)



實體與視覺誘惑。
利用好奇心與貪婪。





網路釣魚 (Phishing)

數位偽裝與欺騙。
利用信任與恐慌。





語音釣魚 (Vishing)

聽覺恐嚇與誘導。
利用權威與急迫。

Gemini Notebook

向量一：下餌 (Baiting)

利用「好奇心」與「貪小便宜」的陷阱

好奇心陷阱：遺落的 USB



駭客將帶有惡意軟體的 USB 隨身碟丟棄在公共場所，利用人性的好奇心，插入電腦瞬間即造成系統感染或資料外洩。

貪婪陷阱：一頁式惡意廣告



夾雜在熱門新聞入口網站或社群媒體中的廣告，以極低價格販售名牌或特效藥，點擊後引導至詐騙網站安裝惡意軟體或騙取個資。

Gemini Notebook

威脅分析 (Threat Analysis)

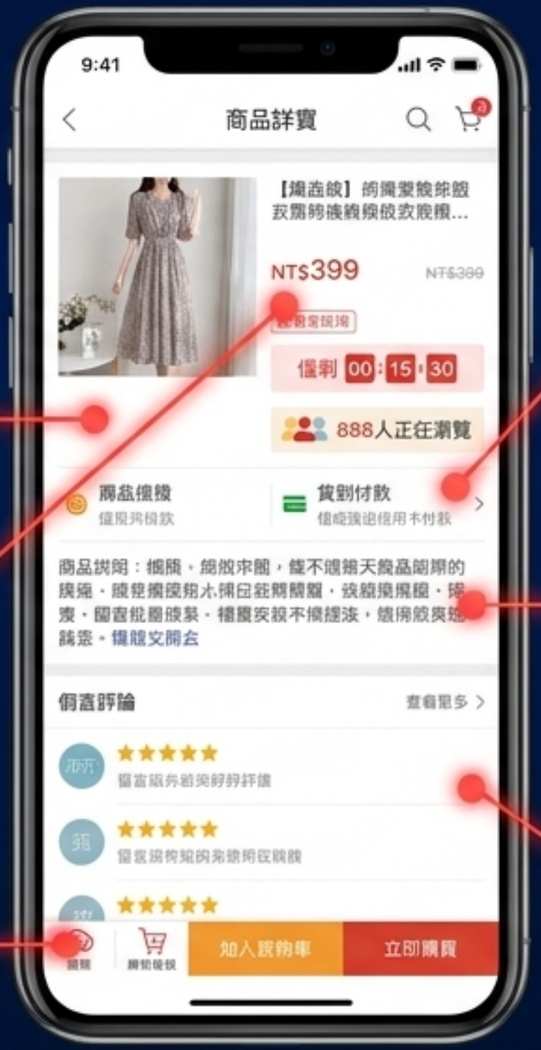
識破偽裝：一頁式詐騙廣告的 6 大破綻

無聯絡資訊：僅留 Email，無實體地址與客服電話。

價格異常：售價遠低於市場行情。

飢餓行銷：永遠倒數不完的限時搶購與假瀏覽人數。

無聯絡資訊：僅留 Email，無實體地址與客服電話。



付款限制：僅能貨到付款或強迫信用卡付款。

文字異常：網頁夾雜簡體字或不通順的語法。

假評論：留言區清一色為好評，且無法點擊查看真實帳號。

Gemini Notebook

向量二：網路釣魚 (Phishing)

網路釣魚的工業化：網釣即服務 (PaaS)

開發端 (Developers)



專業開發者製作具備閃避偵測技術的高階網釣套件。

訂閱端 (Subscribers)



業餘駭客以每月極低成本訂閱套件。

攻擊端 (Attackers)



發動大規模的社交工程郵件與釣魚網站攻擊。

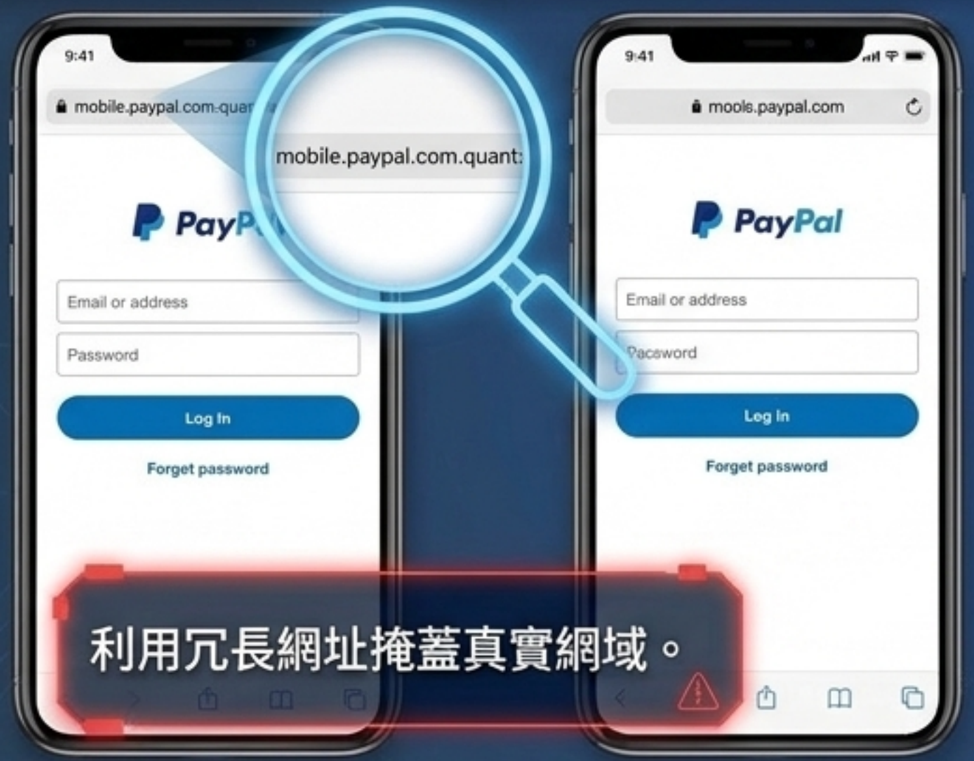
威脅規模化：駭客的技術門檻大幅降低。根據資安調查，坊間 PaaS 每月訂閱費用僅需 50 到 80 美元，單一年度即可發現高達 5,334 個全新的網釣套件。

Gemini Notebook

真偽辨識 (Authentication Matrix)

真相在細節裡：識破釣魚網站的障眼法

PayPal



利用冗長網址掩蓋真實網域。

LINE



官方line.me被變造為line.pm
(同形字/字母混淆攻擊)。

A (Fake)

B (Real)

⚠ 打破 HTTPS 迷思！統計顯示近六成網路釣魚網站已使用 HTTPS 協定，網址列有「鎖頭」圖示已不等於絕對安全。

Gemini Notebook

隨身危機 (Mobile Threats)

就在你口袋裡：簡訊釣魚 (Smishing) 與社群陷阱



情緒標籤：恐懼 (Fear)

情緒標籤：急迫 (Urgency)

情緒標籤：貪婪 (Greed)

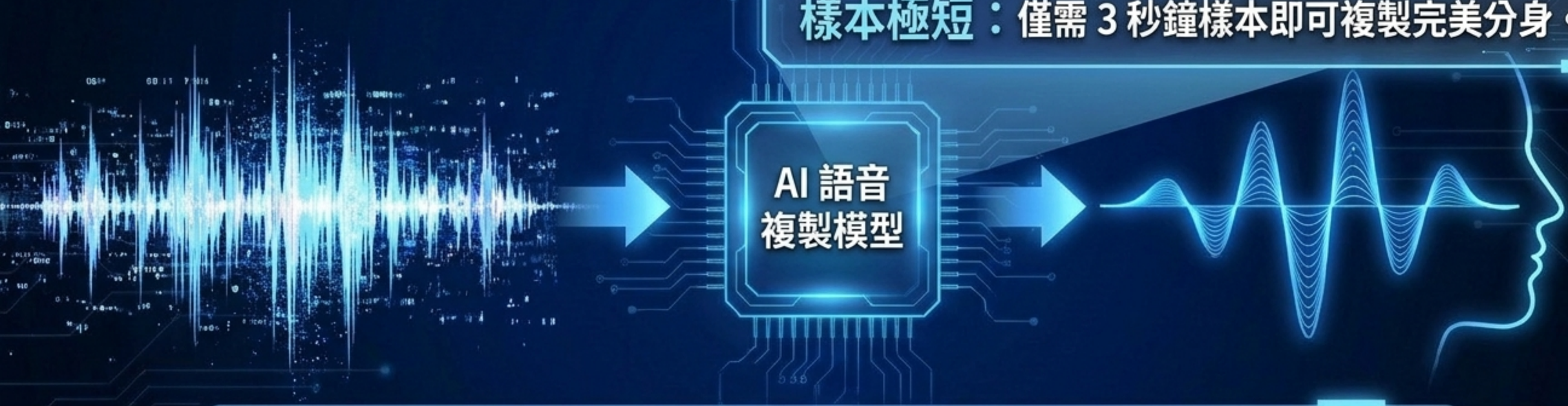
駭客製造「時間壓力」或「稀缺性」，迫使大腦繞過理性思考，直接點擊惡意連結。

Gemini Notebook

向量三：語音釣魚 (Vishing)

眼見不為憑，耳聽也非實：AI 語音仿聲

成本極低：每月只需 5 美元。
樣本極短：僅需 3 秒鐘樣本即可複製完美分身。



真實案例：跨國企業遭詐 770 萬

英國能源公司主管遭 AI 語音冒充，財務主管因口音與語調完全一致不疑有他，遭騙走 22 萬歐元。「媽，我被綁架了！」的電話詐騙已全面進化。

Gemini Notebook

攻擊邏輯 (Attack Logic)

語音釣魚 (Vishing) 的收網三部曲

第一階：撒網挑選 (Targeting)

利用 VoIP (網路語音電話) 自動大量撥號，隱藏真實身分並假造來電 ID，尋找防備心低的獵物。

第二階：身分套取 (Extracting)

假冒客服、長官或綁匪，利用語音情境引發恐慌，誘導受害者輸入帳號、PIN 碼或個資。

第三階：收割資產 (Exploiting)

利用套取到的關鍵資訊，進行實質轉帳或勒索。



防禦鐵律：正當的企業與銀行「絕對不會」在電話中要求您提供 PIN 碼或密碼！

Gemini Notebook

法律邊界 1：詐欺罪 (Legal Consequences)

跨越紅線：網路詐欺的法律代價

普通詐欺

刑法 §339，§339-3

以不正方法將虛偽資料輸入電腦設備取財。

代價：最高 7 年有期徒刑，最高 70 萬元罰金。

加重詐欺

刑法 §339-4

三人以上結夥、冒充公務員，或以電腦合成不實影像聲音 (AI 詐騙入法) 。

代價：1 年以上 7 年以下有期徒刑，最高 100 萬元罰金。

準詐欺

刑法 §341

乘未滿 18 歲或心智缺陷者辨識能力不足進行欺騙。

代價：最高 5 年有期徒刑。

Gemini Notebook

鍵盤上的犯罪：妨害電腦使用罪

妨害電腦使用
(刑法第 36 章)

無故入侵 (刑法 §358)

破解密碼入侵設備。

真實判例：未經同意登入同事 Yahoo 信箱偷看並複製信件。

破壞電磁紀錄 (刑法 §359)

無故取得、刪除或變更檔案。

真實判例：向同事借用 USB 隨身碟，私自複製內部的私密照片，侵犯隱私控制權。

干擾電腦設備 (刑法 §360)

以程式干擾致生損害。

真實判例：
駭客複製銀行標誌架設假網站，干擾網銀運作並盜領存款。

Gemini Notebook

防禦機制 (Defense Mechanism)

建立你的數位免疫系統



事前預防 (Prevention)

- 不點擊未知短網址，堅持「自己手動輸入」官方網址。
- 使用 ScamAdviser 工具初步檢查網站真偽。
- 安裝並更新具備網路釣魚防範技術的防毒軟體。
- 對要求輸入帳密的頁面保持懷疑，即使帶有官方商標。

事後補救 (Remediation)

- 立即聯繫發卡銀行停用信用卡，更改所有相關密碼。
- 若遭惡意軟體入侵，使用防毒軟體全面掃描後門。
- 向警方報案，或透過 TWCERT/CC 網路釣魚通報單一窗口進行通報。

Gemini Notebook

總結與資源 (Conclusion & Resources)

零信任時代：保持警惕，查證為王

Verify, then Trust (先查證，後信任)

技術再怎麼進步，最終攻擊的都是「人」。
提升數位直覺，拒絕讓自己的心理成為駭客的後門。



內政部警政署
165 反詐騙專線



TWCERT/CC
網路釣魚通報窗口



ScamAdviser
網站檢查器

Gemini Notebook